CENTRO UNIVERSITÁRIO DO INSTITUTO MAUÁ DE TECNOLOGIA

ENGENHARIA DE COMPUTAÇÃO

DMITRI: UMA ABORDAGEM EMBARCADA PARA SEGURANÇA E ANÁLISE DE VULNERABILIDADES EM REDES

GIULIANO RODRIGUES TUMOLI
GUILHERME THOMASI RONCA
JOÃO VITOR MARQUES FERRENHA CERQUEIRA
MATHEUS SANTOS FEITOSA
RAFAEL MACIEL BERTANI
...
Orientador: PROF. EVERSON DENIS
...

Resumo

O trabalho propõe o desenvolvimento de um sistema embarcado que identifica, monitora e analisa vulnerabilidades em dispositivos conectados a redes locais. Esse sistema embarcado realiza a descoberta de hosts, identificação de endereços, portas abertas e serviços em execução. A solução é composta pelo agente responsável pela coleta das informações da rede, pelo backend, que processa esses dados e expõe uma API, e por uma aplicação web para visualização das informações e gerenciamento do sistema.

Palavras-chave: Segurança da informação. Redes locais. Vulnerabilidades. Sistema embarcado. Varredura de rede.

Abstract

This work proposes the development of an embedded system that identifies, monitors, and analyzes vulnerabilities in devices connected to local networks. The embedded system performs host discovery, address identification, open port enumeration, and running service detection. The solution consists of an agent responsible for collecting network information, a backend that processes this data and exposes an API, and a web application for information visualization and system management.

Keywords: Information security. Local networks. Vulnerabilities. Embedded system. Network scanning.

1. Introdução

Em um mundo onde a hiperconectividade se torna norma, o crescente aumento de dispositivos conectados expande drasticamente a superfície de ataque disponível a agentes maliciosos e organizações criminosas. Estudos confirmam que dispositivos conectados

frequentemente operam com credenciais padrão de fábrica, firmware desatualizado e ausência de criptografia, condições que facilitam ataques automatizados em larga escala (ZAITSEV et al., 2018).

Embora o Brasil seja um dos países com maior incidência de ataques cibernéticos, a maioria das pessoas e organizações ainda desconhece os riscos reais a que está exposta. O país lidera o ranking de vulnerabilidade digital na América Latina, concentrando 90% das tentativas de ataques cibernéticos da região (SECURITY LEADERS, 2025). Esse cenário é agravado pela escassez de profissionais especializados na área no país, onde a demanda por especialistas cresce em ritmo muito superior à formação de novos profissionais, tornando a automação uma necessidade estrutural para suprir essa lacuna.

Neste contexto, este projeto tem como objetivo analisar, identificar e monitorar vulnerabilidades de forma automatizada e acessível, independentemente do grau de conhecimento técnico do usuário, oferecendo proteção contra falhas já conhecidas e documentadas e, consequentemente, diminuindo assim a superfície de ataque.

1.1. Objetivos

1.1.1 Objetivo Geral

Desenvolver um sistema embarcado capaz de realizar a varredura automatizada de redes locais, identificando e monitorando vulnerabilidades em dispositivos conectados, com o propósito de interpretar os dados coletados e disponibilizá-los por meio de uma interface de fácil utilização e interpretação pelo usuário, possibilitando a visualização das vulnerabilidades encontradas e, quando aplicável, o suporte à atualização de versões dos dispositivos identificados.

1.1.2 Objetivos Específicos

- Implementar um agente de varredura embarcado no Raspberry Pi 4 para descoberta de hosts, enumeração de portas, detecção e versionamento de serviços e coleta de evidências com Nmap e scripts NSE.
- Construir um backend com REST API (Interface de Programação de Aplicações) para recebimento, validação, persistência e consulta dos resultados de varredura.
- Modelar um banco de dados relacional com PostgreSQL, para manter histórico de scans, vulnerabilidades observadas, inventário de dispositivos, usuários, permissões, entre outros elementos previstos no sistema.
- Disponibilizar uma interface web para consulta de scans, dispositivos, findings e indicadores de risco de forma simples, de fácil utilização e não técnica.
- Validar a solução em ambiente controlado, observando a qualidade dos achados produzidos e a adequação do desempenho do hardware embarcado ao cenário de uso proposto.

1.2. Justificativa

O avanço da conectividade global expandiu drasticamente a superfície de ataque de redes domésticas e corporativas. Estimativas indicam que o número de dispositivos Internet das Coisas (IoT) conectados ultrapassa 21 bilhões atualmente, com projeções de 29 bilhões até 2030 (IBSEC, 2025), e o programa Common Vulnerabilities and Exposures (CVE) já catalogou mais de 250 mil vulnerabilidades conhecidas até 2024 (HUDSON; PESSOA, 2025). No Brasil, esse problema é particularmente crítico: o país registrou mais de 60 bilhões de tentativas de ataques cibernéticos em 2023, sendo o mais atacado da América Latina, segundo o relatório FortiGuard Labs da Fortinet (BRASIL..., 2024).

A situação é ainda mais preocupante para pequenas e médias empresas, que frequentemente não possuem equipes especializadas ou recursos suficientes para investir em soluções robustas de cibersegurança. Um estudo global conduzido pela Mastercard, com mais de 5 mil proprietários de pequenas e médias empresas em quatro continentes, revelou que 46% dessas empresas já sofreram ataques cibernéticos, sendo que parte delas chegou a encerrar suas atividades após os incidentes, evidenciando os impactos financeiros e operacionais causados pela ausência de mecanismos adequados de proteção e monitoramento de redes (MASTERCARD, 2025).

Esses dados evidenciam a necessidade de mecanismos de segurança capazes de auxiliar na identificação e no monitoramento de vulnerabilidades de forma acessível, especialmente em organizações que não dispõem de equipes especializadas. Nesse contexto, este projeto insere-se na área de segurança da informação, propondo o desenvolvimento de um sistema embarcado capaz de automatizar a identificação e a análise de vulnerabilidades presentes em uma rede de forma prática, automatizada e acessível.

1.3. Definição do escopo, contextualização e oportunidades

A proteção de dados possui grande importância, tanto para indivíduos em ambiente doméstico protegendo, por exemplo, suas câmeras de vigilância, quanto para empresas, cujas consequências de ataques cibernéticos podem ser potencialmente devastadores. De acordo com a IBM Security (2024), o custo médio por incidente de violação de dados em empresas é de US$ 4,88 milhões, um valor expressivo para muitas empresas.

Entretanto, especialmente em ambientes domésticos e em pequenas empresas, as práticas de segurança de rede não acompanham o nível do risco econômico de violações de dados, o crescimento das redes computacionais, a constante ampliação de dispositivos conectados e o crescimento dos ataques cibernéticos. Como apontado pelo relatório da Verizon (VERIZON, 2023), 43% das organizações afetadas por incidentes são pequenas empresas, das quais apenas 14% estão preparadas para se defender, e somente 26% possuem uma política de segurança implementada (HISCOX GROUP, 2023).

Existem diversos fatores que contribuem para tal cenário. A complexidade de uso das ferramentas de varredura consolidadas, como o Nmap, exige conhecimento técnico especializado, o que limita sua adoção por organizações de menor maturidade. E a escassez de profissionais

especializados agrava o cenário, influenciando em consequências como falhas de configuração, serviços expostos indevidamente e ausência de monitoramento contínuo, o que facilita a exploração de vulnerabilidades por agentes maliciosos.

Tal cenário de escassez de profissionais qualificados e a alta complexidade das ferramentas existentes constitui o ambiente ideal para a proposta de uma solução automatizada capaz de identificar e analisar vulnerabilidades presentes em uma rede de forma prática e acessível, apresentando os resultados de forma acessível e não técnica, contribuindo para que qualquer organização possa identificar e mitigar vulnerabilidades conhecidas, independentemente de possuir uma equipe de segurança dedicada.

1.4. Métodos e Tecnologias

A pesquisa é de natureza aplicada e caráter construtivo: o objetivo central é projetar, implementar e validar um sistema funcional de varredura de vulnerabilidades em rede local. A abordagem metodológica combina revisão bibliográfica, utilizada para embasar as decisões arquiteturais, com estudo de caso aplicado ao laboratório de robótica industrial NSPI (Núcleo de Sistemas Produtivos Inteligentes) da universidade. Cada decisão tecnológica foi submetida a três critérios antes de ser adotada: valor técnico diferencial em relação às alternativas disponíveis, adequação ética e legal para varredura em rede autorizada, e viabilidade de execução no hardware embarcado selecionado.

A plataforma física adotada é o Raspberry Pi 4 com 4 GB de memória RAM e arquitetura ARM64, escolhido dentro de um orçamento de R$1.250 com base na disponibilidade de distribuidores nacionais. O sistema operacional utilizado é o Raspberry Pi OS Lite, em modo headless, pela estabilidade e suporte nativo às ferramentas de varredura. Para captura em modo monitor, o conjunto de hardware inclui o adaptador USB ALFA AWUS036ACM, com chipset MediaTek MT7612U e suporte documentado à família de drivers mac80211 do Linux, mantendo o Wi-Fi integrado reservado para tráfego de gerenciamento.

A varredura de rede é executada pelo Nmap em conjunto com a Nmap Scripting Engine (NSE), selecionados como motor principal pela cobertura abrangente de protocolos e baixo consumo de recursos no hardware embarcado. A correlação de vulnerabilidades com identificadores CVE é realizada pelo script vulners NSE, que opera de forma passiva, sem autenticação nos alvos nem execução remota de código. Scripts complementares cobrem protocolos relevantes ao contexto industrial, como SMB, SSH, HTTP e SSL/TLS. Scanners que exigem infraestrutura pesada, como OpenVAS/Greenbone, que requer no mínimo 4 GB de RAM apenas para sincronização de feed, foram descartados por inviabilidade no hardware embarcado.

Para as camadas de backend e frontend, planejadas para fase posterior do projeto, foram selecionados FastAPI (Python), PostgreSQL via Supabase e React com TypeScript, priorizando geração automática de contratos OpenAPI, operações assíncronas e uma interface de visualização acessível. As decisões técnicas detalhadas estão documentadas nos ADRs do repositório.

2. Revisão Bibliográfica

2.1 Varredura de redes e descoberta de serviços

A descoberta de ativos, a enumeração de portas e a identificação de serviços constituem a base técnica de plataformas de avaliação de exposição em rede. Lyon (2009) descreve o Nmap como uma ferramenta de exploração e auditoria de rede capaz de determinar quais hosts estão ativos, quais serviços e versões estão sendo oferecidos e quais características adicionais podem ser inferidas a partir do comportamento de resposta dos alvos. Essa abordagem por múltiplas fases é particularmente relevante para o presente trabalho, pois permite modularidade, adaptação de perfis de varredura e controle sobre custo computacional, aspectos importantes em dispositivos embarcados.

A literatura técnica também evidencia que a qualidade da detecção de serviços é decisiva para etapas posteriores de correlação de vulnerabilidades. A identificação incorreta ou incompleta de produto e versão pode comprometer tanto o mapeamento para CVEs quanto a qualidade das recomendações de remediação. Por isso, a separação entre descoberta de hosts, enumeração de portas, detecção de serviços e execução seletiva de scripts representa uma estratégia coerente com o estado da prática descrito na documentação oficial do Nmap (LYON, 2009).

2.2 Identificação padronizada de vulnerabilidades

Para que os achados de segurança sejam interoperáveis entre ferramentas e compreensíveis por diferentes atores, é necessário adotar mecanismos padronizados de identificação. O CVE Program tem como propósito principal identificar unicamente vulnerabilidades e associá-las a versões específicas de bases de código, permitindo que diferentes organizações se refiram ao mesmo problema por um identificador comum (CVE PROGRAM, [s.d.]).

O NVD complementa esse papel ao atuar como repositório governamental de dados padronizados de gerenciamento de vulnerabilidades, incluindo falhas de software, nomes de produtos e métricas de impacto, em formato adequado à automação (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY, [s.d.]). Em conjunto, CVE e NVD fornecem um eixo de normalização que favorece persistência estruturada, consulta histórica e integração com mecanismos de enriquecimento.

2.3 Priorização de vulnerabilidades e contexto de exploração

Um dos principais desafios do gerenciamento de vulnerabilidades está em distinguir falhas teoricamente severas daquelas que, na prática, demandam maior urgência de remediação. Jacobs et al. (2021) observam que estratégias tradicionais baseadas apenas em severidade frequentemente são insuficientes para priorizar de modo eficaz, especialmente em cenários com grande volume de CVEs. Como resposta a essa limitação, o Exploit Prediction Scoring System (EPSS) propõe um modelo orientado por dados para estimar a probabilidade de exploração de uma vulnerabilidade,

atualmente em janelas de curto prazo, e publica seus resultados em formato acessível para integração com fluxos de defesa (FIRST, [s.d.]).

A combinação entre um identificador comum, metadados estruturados, evidências de exploração observada e estimativas probabilísticas cria uma base conceitual robusta para a evolução deste projeto, permitindo construir um score de risco mais informativo do que o uso isolado de severidade.

2.4 LLMs aplicados à cibersegurança

Revisões recentes indicam que modelos de linguagem de grande escala (LLMs) têm sido aplicados a um conjunto crescente de tarefas em cibersegurança, incluindo detecção de vulnerabilidades, análise de malware, triagem de eventos e suporte à tomada de decisão (SILVA; WESTPHALL, 2024; XU et al., 2024). Ainda assim, os autores apontam limitações importantes relacionadas à confiabilidade das respostas, à possibilidade de alucinações e à necessidade de contexto técnico estruturado para reduzir ambiguidades.

Nesse sentido, o presente trabalho adota uma posição deliberadamente conservadora: o modelo de linguagem não é tratado como executor autônomo de ações na rede, mas como um componente assistivo para sumarização, explicação e priorização dos dados já persistidos pela plataforma.

2.5 Trabalhos Relacionados

Diversas soluções comerciais, open-source e acadêmicas foram desenvolvidas para realizar varredura e gerenciamento de vulnerabilidades. Elas podem ser agrupadas em duas categorias principais: ferramentas profissionais/enterprise e soluções mais leves ou voltadas para ambientes de baixo custo.

No segmento profissional, destacam-se o Nessus (Tenable) e o OpenVAS/Greenbone. O Nessus é um dos scanners mais consolidados do mercado, oferecendo detecção abrangente, relatórios avançados e suporte a autenticação. Seu preço para a versão Nessus Professional é de aproximadamente US$ 4.790 por ano por scanner (com scanning ilimitado de IPs), enquanto a versão Nessus Expert custa aproximadamente US$ 6.790 por ano (TENABLE, 2026). Já o OpenVAS, mantido pela Greenbone, oferece uma solução enterprise-grade open-source com suporte pago. A assinatura OpenVAS Basic custa cerca de € 2.524 por ano, representando uma opção mais acessível dentro do segmento profissional (GREENBONE NETWORKS, 2026).

Embora robustas e ricas em funcionalidades, essas soluções apresentam limitações significativas para o contexto deste trabalho: alto custo de aquisição e manutenção, exigência de recursos computacionais elevados e interfaces complexas, o que as torna pouco viáveis para pequenas empresas, ambientes residenciais e usuários com conhecimento técnico limitado.

No âmbito de soluções open-source leves e executáveis em hardware de baixo custo, o Vuls se destaca. Desenvolvido pela Future Architect, o Vuls é um scanner agentless focado em vulnerabilidades de pacotes e dependências em sistemas Linux (incluindo Raspbian), com integração

a múltiplas fontes de inteligência (NVD, CISA KEV, Exploit Database etc.). Ele suporta execução em Raspberry Pi e geração de relatórios periódicos, sendo uma opção viável para administradores de sistemas com restrições de custo (FUTURE ARCHITECT, 2025). No entanto, seu foco principal está na análise de pacotes instalados via SSH ou modo local, com menor ênfase em descoberta ativa de rede, enumeração detalhada de serviços e correlação em tempo real de dispositivos não gerenciados.

Estudos acadêmicos e técnicos também reforçam a viabilidade do uso de Raspberry Pi em segurança. Sainz-Raso et al. (2019) analisam as fraquezas de segurança nativas do Raspberry Pi, enquanto outros trabalhos exploram sua aplicação prática em cenários de pentest e auditoria IoT. No contexto deste trabalho, tais limitações foram consideradas desde o início do projeto. O DMITRI adota configurações headless, hardening do sistema operacional, autenticação forte via HMAC para o agente e execução mínima de serviços, visando minimizar a superfície de ataque do próprio dispositivo de varredura.

2.6 Padrões de assessment de segurança

Para orientar a arquitetura de coleta, análise e resposta do DMITRI, o projeto adota como referencial os padrões consolidados de assessment de segurança propostos pelo NIST. O NIST SP 800-115 (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY, 2008) descreve um ciclo composto por quatro fases, planejamento, execução dos testes técnicos, análise dos achados e elaboração de estratégias de mitigação.

O NIST Cybersecurity Framework 2.0 (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY, 2024) complementa essa perspectiva ao situar o resultado de um assessment técnico dentro de um ciclo mais amplo de gestão de risco, organizado em funções como inventário, detecção, resposta e governança.

O DMITRI adota essa lógica como referencial de projeto. A execução do agente segue uma sequência análoga às fases do SP 800-115: delimitação de escopo e perfil de scan antes da varredura, execução controlada dos testes técnicos, normalização dos achados em formato estruturado e, por fim, priorização orientada à ação. Já a incorporação de um score de risco e a organização dos achados por ativo aproximam a solução das funções de identificação e detecção descritas pelo CSF 2.0, situando o produto do scan como etapa inicial de um ciclo maior de gestão de risco, e não como relatório isolado.

3. Desenvolvimento

O desenvolvimento da solução foi organizado como um pipeline distribuído e incremental, no qual cada componente assume responsabilidades específicas na coleta, no tratamento, no armazenamento e na interpretação dos dados de segurança. A arquitetura proposta consiste em um agente embarcado executado em Raspberry Pi 4, conectado à rede local, integrando esse agente a uma plataforma web, com backend, banco PostgreSQL, worker de processamento e interface de visualização.

3.1 Arquitetura geral da solução

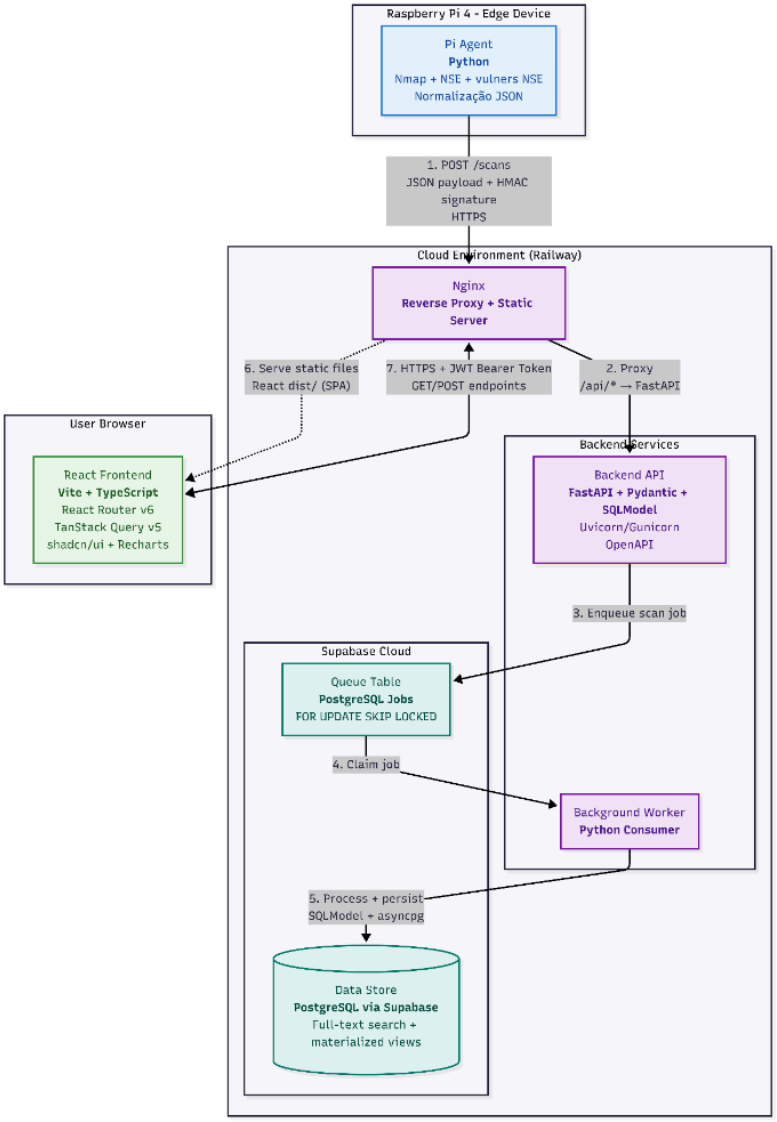
A arquitetura do DMITRI foi projetada com base nos princípios de separação de responsabilidades, escalabilidade e evolutividade. O sistema adota uma abordagem híbrida, combinando um agente embarcado para coleta de dados diretamente na rede local com uma plataforma backend em nuvem para processamento, armazenamento e visualização das informações.

O sistema é composto por cinco componentes principais:

- Hardware Agent — executado em Raspberry Pi 4;
- Backend API — responsável pelo recebimento e orquestração;
- Background Worker — processamento assíncrono de enriquecimento;
- Banco de Dados — PostgreSQL para persistência centralizada;
- Frontend Web — interface de visualização e interação.

Essa divisão modular permite que cada parte do sistema opere de forma otimizada, reduzindo o acoplamento entre os componentes e facilitando a manutenção e a evolução incremental do projeto. A Figura 1 apresenta uma visão geral da arquitetura da aplicação.

Figura 1 – Arquitetura geral da solução



Fonte: Elaborado pelos autores

3.1.1 Descrição do Fluxo Principal:

1. O Hardware Agent, executando no Raspberry Pi 4, realiza as varreduras na rede local utilizando Nmap e scripts NSE, normaliza os resultados em formato JSON estruturado e os envia de forma segura para o Backend.
2. O Backend API recebe o payload, realiza validações e enfileira a tarefa de processamento.
3. O Background Worker consome os jobs da fila, executa o enriquecimento dos achados (correlação de vulnerabilidades, cálculo de risco, etc.) e persiste os dados no banco.
4. O Frontend Web consome a API para exibir dashboards, histórico de scans, inventário de dispositivos, findings e recomendações de priorização.

Essa arquitetura oferece vantagens significativas: permite a execução eficiente em hardware com recursos limitados, mantém o processamento pesado fora do dispositivo embarcado, garante histórico completo e auditável dos scans, e separa claramente as etapas de coleta, enriquecimento e apresentação.

3.2 Pipeline de varredura no agente embarcado

O agente embarcado implementa um pipeline de múltiplos estágios inspirado nas fases clássicas de varredura descritas por Lyon (2009) e alinhado ao ciclo de assessment técnico descrito na Seção 2.6. O pipeline é organizado em quatro etapas sequenciais, nas quais a saída de uma etapa delimita o escopo de trabalho da etapa seguinte.

Na primeira etapa, realiza-se a descoberta de hosts ativos no alvo configurado, mapeando quais endereços respondem antes de qualquer tentativa de varredura de portas. Em seguida, realiza-se a enumeração de portas abertas, restrita ao conjunto de portas definido pelo perfil de scan selecionado, o que permite equilibrar profundidade de cobertura e tempo de execução conforme o cenário de uso. Na terceira etapa, realiza-se a detecção de serviços e versões nas portas observadas, identificando o que está em execução em cada porta aberta e em qual versão. Por fim, scripts NSE são executados para inspeção adicional e correlação de vulnerabilidades: o script *vulners* associa cada par serviço/versão identificado a CVEs conhecidas, respeitando um limiar mínimo de CVSS configurável por perfil de scan, de modo que apenas achados acima da severidade definida sejam reportados como findings.

Esta segmentação por estágios, na qual cada fase delimita o escopo da seguinte, permite escalonar profundidade conforme o perfil de scan, preservando a viabilidade operacional da solução. Ao final da execução, o agente produz um payload JSON contendo metadados do scan, inventário de dispositivos, portas observadas, serviços identificados, artefatos gerados e findings correlacionados.

3.3 Backend, persistência e processamento assíncrono

O backend foi projetado em FastAPI, expondo endpoints para ingestão e consulta dos resultados. A ingestão do payload produzido pelo agente ocorre por meio de um endpoint POST, responsável por persistir de forma imediata as entidades scan, devices, ports e findings recebidas e por enfileirar os respectivos jobs de enriquecimento, devolvendo resposta rápida ao agente sem aguardar o processamento analítico completo. Os dados recebidos são validados por schemas tipados e persistidos em PostgreSQL, com modelagem orientada a entidades como scan, device, port, service, finding, artifact e job de enriquecimento. Essa estrutura favorece consultas históricas, detalhamento por ativo e reconstrução do contexto de cada execução.

Uma decisão importante de implementação é a separação entre ingestão e enriquecimento. Em vez de concentrar toda a lógica analítica na mesma transação de recebimento do scan, o sistema utiliza uma fila baseada no próprio PostgreSQL para registrar jobs pendentes, sem depender de um broker de mensagens externo. Os workers de enriquecimento reivindicam lotes de jobs dessa fila de forma concorrente e segura, diretamente no banco de dados, o que elimina uma peça adicional de infraestrutura a operar e simplifica a topologia do sistema. Essa estratégia reduz dependências externas, preserva simplicidade arquitetural e mantém aderência ao porte do projeto, sem renunciar a extensibilidade.

3.4 Modelo de cálculo de risco

Para viabilizar a priorização de findings prevista no ciclo descrito na Seção 2.6, o worker de enriquecimento calcula, para cada achado, um score de risco normalizado em uma escala de 0 a 100. O score combina quatro componentes, cada um associado a um peso que reflete sua contribuição relativa para a urgência de remediação:

$$\text{score} = \text{severity}\cdot 0{,}45 + \text{exploitability}\cdot 0{,}35 + \text{confidence}\cdot 0{,}15 + \text{exposed}\cdot 0{,}05$$

O componente *severity* representa a gravidade técnica do achado, derivada diretamente da métrica CVSS associada à CVE correlacionada. O componente *exploitability* estima a probabilidade e a evidência de exploração ativa da vulnerabilidade, combinando três fontes de enriquecimento consultadas pelo worker: a pontuação do EPSS, que expressa a probabilidade estatística de exploração em janela de curto prazo (FIRST, [s.d.]); a presença da CVE no catálogo CISA Known Exploited Vulnerabilities (KEV), como indicador de exploração ativa observada; e um sinalizador de associação a campanhas de ransomware. Esses três sinais são combinados pela expressão $\text{exploitability} = \min(1, \text{epss}\cdot 0{,}7 + \text{kev}\cdot 0{,}3 + \text{ransomware}\cdot 0{,}1)$, de modo que evidência de exploração já observada (KEV) e associação a ransomware elevem o score mesmo quando a probabilidade estatística isolada do EPSS for moderada.

O componente *confidence* pondera o grau de certeza da detecção que originou o achado, atribuindo peso maior a detecções confirmadas do que a inferências realizadas a partir de banners ou versões parcialmente identificadas. Por fim, o componente *exposed* aplica um ajuste marginal ao score quando o serviço vulnerável está, de fato, exposto e acessível na rede, e não apenas presente no host.

Esta ponderação adotada concentra 80% do peso total nos componentes de severidade e exploração, refletindo a decisão de priorizar achados que sejam simultaneamente graves e exploráveis, em detrimento de vulnerabilidades teoricamente severas, mas sem evidência de exploração, abordagem alinhada à limitação apontada por Jacobs et al. (2021) quanto à priorização baseada isoladamente em severidade.

3.5 Camada de análise assistida por LLMs

Como etapa avançada do desenvolvimento, a solução prevê a incorporação de um componente assistivo baseado em modelo de linguagem. Seu papel não será executar ações autônomas sobre os alvos, mas sintetizar resultados, explicar por que um finding merece atenção, sugerir prioridades de remediação e apontar lacunas de evidência. Essa decisão está alinhada com a literatura recente, que reconhece o potencial dos LLMs em tarefas analíticas, mas também ressalta riscos de confiabilidade quando tais modelos atuam sem contexto estruturado ou sem mecanismos adequados de controle (SILVA; WESTPHALL, 2024; XU et al., 2024).

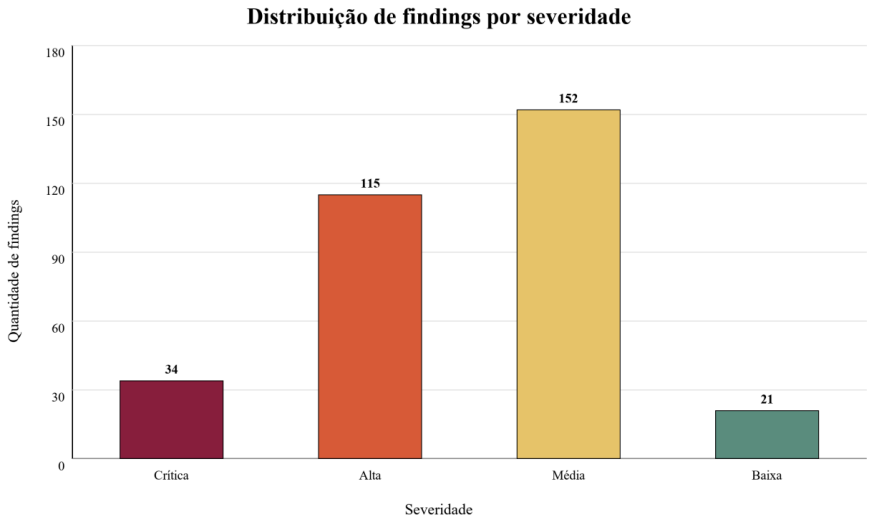
4. Resultados

4.1 Validação funcional do agente

Os resultados obtidos indicam que o DMITRI atendeu ao objetivo de implementar as etapas centrais de uma varredura automatizada de rede local. Em ambiente de desenvolvimento, com testes realizados no computador, o agente foi capaz de executar descoberta de hosts, enumeração de portas, identificação de serviços e correlação inicial de vulnerabilidades, produzindo saídas estruturadas compatíveis com a arquitetura proposta. A organização do processo em múltiplos estágios mostrou-se adequada ao problema abordado, pois permitiu que cada etapa alimentasse a seguinte de forma progressiva, reduzindo processamento desnecessário e favorecendo o uso eficiente dos recursos disponíveis.

Em um dos testes realizados em ambiente de desenvolvimento usando uma máquina propositalmente vulnerável (Metasploitable), sobre a sub-rede 192.168.56.0/24 no modo extensive, o agente identificou 3 hosts, produziu 322 findings e concluiu a execução em 389,24 segundos. Nesse cenário, foram observados exemplos concretos de achados relevantes, como correlação de CVE para o serviço vsftpd 2.3.4 exposto na porta 21, detecção de login FTP anônimo, identificação de autenticação por senha em SSH, exposição de caminhos sensíveis em aplicação web, como /admin e /manager, e sessões SMB anônimas em um host Windows. Esses resultados indicam que o pipeline foi capaz de transformar evidências técnicas heterogêneas em achados estruturados e interpretáveis. Abaixo tem-se o Gráfico 1 que representa a distribuição de findings por severidade.

Gráfico 1 - Distribuição de findings por severidade



Fonte: Elaborado pelos autores.

4.2 Adequação ao cenário proposto e limitações da validação atual

Embora a arquitetura do projeto tenha sido concebida para execução embarcada em Raspberry Pi 4, os resultados desta etapa referem-se à validação funcional realizada em computador de desenvolvimento. Assim, foi possível verificar o funcionamento do pipeline de varredura e da estruturação dos resultados, mas não ainda caracterizar, de forma conclusiva, o desempenho da solução no hardware embarcado proposto.

4.3 Comparação com ferramentas e abordagens existentes

Em comparação com soluções como Nessus e OpenVAS, o DMITRI não busca competir em abrangência de cobertura ou volume de funcionalidades corporativas, mas se destaca por propor uma alternativa de menor custo, maior simplicidade operacional e arquitetura voltada à futura execução embarcada (TENABLE, 2026; GREENBONE NETWORKS, 2026). Em relação ao uso isolado do Nmap, a principal contribuição da solução está na integração do processo de coleta, estruturação e preparação dos resultados para uso posterior. Também se observa diferença em relação ao Vuls, cujo foco está na análise de pacotes instalados em hosts gerenciados. Abaixo tem-se a Tabela 1 que compara com ferramentas existentes.

Tabela 1 – Comparação entre DMITRI e ferramentas existentes

Ferramenta/abordagem	Custo indicado no artigo	Foco principal	Funcionalidades principais	Adequação a hardware embarcado	Limitações em relação ao problema do trabalho
DMITRI	Aproximadamente R$ 1.250, considerando o hardware Raspberry Pi 4	Varredura automatizada de redes locais em solução embarcada	Mapeamento automático de dispositivos na rede, identificação de portas e serviços ativos, coleta e organização padronizada dos dados em formato JSON, armazenamento local dos resultados e integração planejada com sistemas de análise e visualização	Alta: projetado especificamente para execução em Raspberry Pi 4	Ainda depende da implementação completa das camadas de persistência remota, visualização web e enriquecimento com KEV/EPSS
Nessus	Nessus Professional: aproximadamente US$ 4.790/ano por scanner; Nessus Expert: aproximadamente US$ 6.790/ano	Scanner profissional de vulnerabilidades	Avaliação abrangente de vulnerabilidades, identificação de configurações inseguras, geração de relatórios detalhados, suporte a verificações autenticadas e recursos avançados para ambientes corporativos	Baixa: solução voltada a ambientes profissionais, com maior exigência de infraestrutura	Alto custo e complexidade operacional para pequenas empresas, ambientes residenciais e usuários com menor conhecimento técnico
OpenVAS/Greenbone	OpenVAS Basic: cerca de € 2.524/ano	Scanner profissional/*open-source* com suporte pago	Detecção de vulnerabilidades conhecidas, gerenciamento contínuo da superfície de ataque, emissão de relatórios técnicos e suporte a processos de monitoramento e gestão de riscos em ambientes corporativos	Baixa: exige infraestrutura mais robusta; soluções como OpenVAS/Greenbone demandam recursos elevados	Menor viabilidade para hardware embarcado e para organizações com restrição de orçamento ou equipe técnica

Fonte: Elaborado pelos autores.

5. Considerações Finais

Este trabalho apresentou o desenvolvimento do DMITRI, uma solução voltada à identificação e análise automatizada de vulnerabilidades em redes locais. A partir dos resultados obtidos, conclui-se que o objetivo geral da pesquisa foi parcialmente alcançado nesta etapa, uma vez que foi possível implementar e validar funcionalmente um agente capaz de descobrir hosts, enumerar portas, identificar serviços e estruturar os achados de forma reutilizável pelas demais camadas da plataforma.

A principal contribuição do estudo está em demonstrar que práticas consolidadas de varredura de rede podem ser organizadas em uma arquitetura modular, de baixo custo e preparada para futura execução embarcada. Ao mesmo tempo, a estruturação dos resultados amplia o potencial de evolução da solução em direção a persistência, visualização e enriquecimento posterior.

Como limitações, destacam-se o fato de a validação ter sido realizada em ambiente de desenvolvimento no computador, a dependência da qualidade da identificação de serviços e a ausência, até o momento, de testes conclusivos no Raspberry Pi 4. Como trabalhos futuros, recomenda-se realizar a validação embarcada completa, medir o desempenho da solução no hardware-alvo e evoluir os mecanismos de persistência, enriquecimento dos achados e apoio ao usuário.

Referências

BRASIL sofreu 60 bilhões de tentativas de ataques em 2023. **CISO Advisor**, 2024. Disponível em: https://www.cisoadvisor.com.br/brasil-sofreu-60-bilhoes-de-tentativas-de-ataques-em-2023/. Acesso em: 18 maio 2026.

CVE PROGRAM. **Common Vulnerabilities and Exposures (CVE)**. [S. l.], [s. d.]. Disponível em: https://www.cve.org/about/overview. Acesso em: 12 maio 2026.

FIRST. **Exploit Prediction Scoring System (EPSS)**. [S. l.], [s. d.]. Disponível em: https://www.first.org/epss/. Acesso em: 12 maio 2026.

FUTURE ARCHITECT. **Vuls: agent-less vulnerability scanner**. [S. l.], 2025. Disponível em: https://github.com/future-architect/vuls. Acesso em: 18 maio 2026.

GREENBONE NETWORKS. **OpenVAS Basic – Pricing**. [S. l.], 2026. Disponível em: https://www.greenbone.net/en/openvas-basic-order/. Acesso em: 18 maio 2026.

HISCOX GROUP. **Hiscox Cyber Readiness Report 2023**. [S. l.]: Hiscox Group, 2023. Disponível em: https://www.hiscoxgroup.com/cyber-readiness. Acesso em: 18 maio 2026.

HUDSON, Clinton; PESSOA, Moreira. **Catálogo de vulnerabilidades de segurança em sistemas de software IoT**. [S. l.: s. n.], 2025. Disponível em: https://pesc.coppe.ufrj.br/uploadfile/publicacao/3218.pdf. Acesso em: 18 maio 2026.

IBM SECURITY. **Cost of a Data Breach Report 2024**. [S. l.]: IBM Corporation, 2024. Disponível em: https://www.ibm.com/reports/data-breach. Acesso em: 18 maio 2026.

IBSEC. **10 vulnerabilidades críticas em dispositivos IoT**. São Paulo: IBSEC, 2025. Disponível em: https://ibsec.com.br/10-vulnerabilidades-criticas-em-dispositivos-iot/. Acesso em: 18 maio 2026.

JACOBS, Jay; ROMANOSKY, Sasha; EDWARDS, Benjamin; ROYTMAN, Michael; ADJERID, Idris. Exploit Prediction Scoring System (EPSS). **Digital Threats: Research and Practice**, New York, v. 2, n. 3, 2021. Disponível em: https://doi.org/10.1145/3436242. Acesso em: 12 maio 2026.

LYON, Gordon. **Nmap Network Scanning: the official Nmap Project guide to network discovery and security scanning**. [S. l.]: Insecure.Com LLC, 2009.

MASTERCARD. Small business cybersecurity: survey shows reason for worry. **Mastercard News & Trends**, 2025. Disponível em: https://www.mastercard.com/global/en/news-and-trends/stories/2025/small-business-cybersecurity-study.html. Acesso em: 18 maio 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **National Vulnerability Database**. [S. l.], [s. d.]. Disponível em: https://nvd.nist.gov/. Acesso em: 12 maio 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Technical Guide to Information Security Testing and Assessment** (NIST SP 800-115). Gaithersburg: NIST, 2008. Disponível em: https://doi.org/10.6028/NIST.SP.800-115. Acesso em: 18 maio 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **The NIST Cybersecurity Framework (CSF) 2.0**. Gaithersburg: NIST, 2024. Disponível em: https://doi.org/10.6028/NIST.CSWP.29. Acesso em: 18 maio 2026.

SAINZ-RASO, Jorge et al. Security Vulnerabilities in Raspberry Pi – Analysis of the System Weaknesses. **IEEE Consumer Electronics Magazine**, v. 8, n. 6, p. 47-52, 2019.

SECURITY LEADERS. Brasil lidera ranking de vulnerabilidade digital na América Latina. **Security Leaders**, 2025. Disponível em: https://www.securityleaders.com.br. Acesso em: 18 maio 2026.

SILVA, Gabriel de Jesus Coelho da; WESTPHALL, Carlos Becker. A Survey of Large Language Models in Cybersecurity. **arXiv**, 2024. Disponível em: https://doi.org/10.48550/arXiv.2402.16968. Acesso em: 12 maio 2026.

TENABLE. **Nessus Vulnerability Scanner – Pricing**. [S. l.], 2026. Disponível em: https://www.tenable.com/buy. Acesso em: 18 maio 2026.

VERIZON. **Data Breach Investigations Report 2023**. [S. l.]: Verizon Business, 2023. Disponível em: https://www.verizon.com/business/resources/reports/dbir/. Acesso em: 18 maio 2026.

XU, Hanxiang; WANG, Shenao; LI, Ningke; WANG, Kailong; ZHAO, Yanjie; CHEN, Kai; YU, Ting; LIU, Yang; WANG, Haoyu. Large Language Models for Cyber Security: a systematic literature review. **arXiv**, 2024. Disponível em: https://doi.org/10.48550/arXiv.2405.04760. Acesso em: 12 maio 2026.

ZAITSEV, Oleg; BUCHKA, Nikita; EREMIN, Alexander et al. IoT lottery: finding a perfectly secure connected device. **Securelist**, 2018. Disponível em: https://securelist.com/iot-lottery/83300/. Acesso em: 17 maio 2026.